

Firewalls



Firewalls & Web Application Firewall

- Firewalls
- What is Firewall?
- Firewall Design Principles
- Things to consider when sizing
- Firewall Hardening
- Firewall policies
- Types of Firewall
- Advantages and Disadvantages of Firewall
- Firewall Throughput
- SSL Decryption

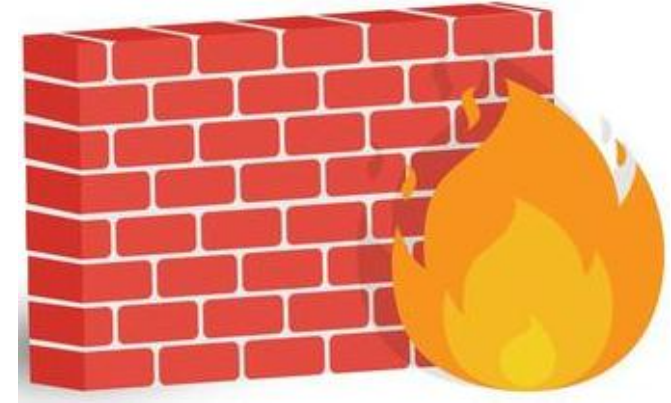


Labs

- Block an application based on AppID
- URL Filtering advanced

Firewalls

- A firewall is a security device—either hardware, software, or a combination of both—that monitors, filters, and controls incoming and outgoing network traffic based on predefined security policies.
- A firewall is the foundational security component of any network.
- *It filters traffic, enforces access rules, prevents cyberattacks, and supports Zero Trust by controlling connectivity between users, devices, applications, and networks.*
- A firewall is a network security system that acts as a barrier between a trusted internal network (LAN) and untrusted external networks (like the internet). It inspects traffic using rules and decides whether to allow, deny, or inspect deeper.



Firewall's critical functions

❑ Packet Filtering

- Analyzes packets based on IP addresses, ports, and protocols.

❑ Stateful Inspection

- Tracks the state of active connections and makes decisions based on the context of the traffic.

❑ Proxy and Deep Packet Inspection (DPI)

- Interprets application-layer data to detect malware, intrusions, or policy violations.

❑ Network Address Translation (NAT)

- Hides internal IP addresses from the outside world.

Firewall's critical functions

❑ Access Control

- Implements rules that define what traffic is permitted or blocked.

❑ Threat Prevention (in NGFWs)

- Modern firewalls include:
 - Intrusion Prevention System (IPS)
 - Antivirus scanning
 - URL filtering
 - Application control
 - SSL/TLS inspection



Types of Firewalls

- **Packet-Filtering Firewalls**

- Based on Layer 3 (IP) and Layer 4 (ports).
- Legacy type—simple but limited.

- **Stateful Firewalls**

- Track sessions and connection states.
- Most enterprise firewalls use this model.

- **Next-Generation Firewalls (NGFW)**

- Inspect packets at Layer 7, understand applications, scan for threats, and enforce granular security.



Types of Firewalls

- **Proxy Firewalls**

- Act as intermediaries for requests from clients, providing deep inspection and anonymity.

- **Cloud Firewalls**

- Firewall-as-a-Service (FWaaS) deployed in cloud infrastructures (Azure Firewall, AWS WAF, etc.).

- **Host-Based Firewalls**

- Installed on endpoints (Windows Firewall, Linux IPTables) to protect individual systems.

- **Web Application Firewall (WAF)**

- Protects your web applications (HTTPS)
 - Defends against the web-based attacks.

Typical Firewall Placement

Firewalls are usually placed at:

- **Network Perimeter:** Between internal network and the Internet
- **DMZ Boundaries:** For public-facing servers
- **Between VLANs/Zones:** For segmentation & Zero Trust
- **Cloud VNet/VPC boundaries**

Why Firewalls?

1. Protects against unauthorized access
2. Reduces lateral movement for attackers
3. Enforces compliance policies (PCI, HIPAA, ISO27001)
4. Provides visibility into network activity
5. Blocks malware, exploits, and suspicious traffic
6. Enables secure remote access (VPN integration)

Firewall Design Principles

- Firewall design is built on multiple architectural, operational, and security guidelines.
- Firewall design in network security is guided by a small set of core principles:
 - enforce a default-deny policy,
 - apply least privilege,
 - ensure all traffic passes through controlled choke points,
 - use defense-in-depth with segmentation, and
 - harden the firewall platform itself.

Core design principles

- **All traffic through the firewall:**

- The network must be arranged so that any traffic between trusted and untrusted zones is forced through one or more firewalls, with no side paths or backdoor connections.
- This ensures that policy is actually enforceable and logs are generating for every flow.

- **Default deny (allow-list only):**

- By default, all inbound and often most outbound traffic is blocked, and only explicitly permitted flows are allowed, usually using an allow-list approach.
- This sharply limits exposure from forgotten services and misconfigurations.

Least privilege and policy

- **Least privilege access:**

- Rules allow only the minimum required ports, protocols, and destinations for each application or role, avoiding broad “any-any” rules.
- This reduces the blast radius if an account, host, or segment is compromised.

- **Clear, simple security policy:**

- Firewall rules should directly implement a written security policy, kept as simple and human-readable as possible to reduce errors.
- Regular rule reviews remove obsolete or overly permissive entries that accumulate over time.

Defense in depth and segmentation

- **Layered defenses:**

- Firewalls are deployed in multiple layers (perimeter, DMZ, internal segments, sometimes host firewalls) so that breaching one control does not expose the entire network.
- This aligns with broader defense-in-depth strategies in network security architectures.

- **Network segmentation and DMZs:**

- Different security zones (internet, DMZ, internal, sensitive/regulated networks) are separated by firewalls, often with additional micro-segmentation inside.
- Traffic between segments is strictly filtered, limiting lateral movement by attackers.



Secure platform and management

- **Hardened, trusted firewall platform:**

- The firewall itself must run on a secure, patched system designed to resist direct compromise.
- Unnecessary services are disabled and management access is tightly restricted and monitored.

- **Robust management, logging, and monitoring:**

- Centralized management, comprehensive logging, and alerting are essential so changes are controlled and suspicious traffic or rule changes are detected quickly.

Firewall Hardening

- Firewall hardening is the process of securing a firewall's operating system, configuration, and management so it cannot be easily bypassed or taken over, while still enforcing strict, least-privilege traffic rules.
- It focuses on reducing the attack surface of the firewall itself as a critical security control.
- Firewall hardening strengthens the confidentiality, integrity, and availability (CIA) of the network by ensuring that the firewall itself does not become a point of compromise.
- Hardening is a critical component of perimeter defense and aligns with best practices such as [NIST SP 800-41](#), [CIS Benchmarks](#), and [Zero Trust principles](#).



Objectives of Firewall Hardening

- *Reduce the attack surface* of the firewall appliance.
- Ensure *secure and minimal access* to management interfaces.
- Apply *strong, consistent* access control policies.
- Prevent configuration drift and *unauthorized changes*.
- Ensure *logging, auditing, and monitoring* are enabled.
- *Reduce risk of misconfiguration*, a major cause of breaches.



Firewall Hardening – Physical & OS

- **Physical and Infrastructure Hardening**

- Deploy firewalls in secure data centre racks.
- Use restricted physical access controls (biometric/ID badge).
- Isolate management networks using dedicated Mgmt ports.
- Use UPS/dual power feeds for high availability.

- **Operating System / Firmware Hardening**

- Upgrade to the latest stable firmware/software release.
- Apply security patches promptly.
- Disable unused firewall modules or services (e.g., Telnet, HTTP).
- Disable legacy cryptographic protocols (SSLv2/v3, TLS 1.0/1.1).
- Use secure algorithms (AES-256, SHA256).



Firewall Hardening – Management Plane

- **Interface Hardening**

- Restrict management access to specific IPs or subnets.
- Enforce HTTPS/SSH for administration.
- Disable HTTP, Telnet, SNMPv1/v2c.
- Implement two-factor authentication (2FA) for admin sessions.

- **User & Role Hardening**

- Use role-based access control (RBAC).
- Enforce least-privilege access.
- Disable unused admin accounts.
- Enforce strong password policies with expiration.

- **Management Network Segregation**

- Place firewall management in a dedicated management VLAN/subnet.
- No management access from untrusted or DMZ networks.

Firewall Hardening – Control & Data Plane

- **Control Plane Hardening**

- Rate-limit firewall control-plane traffic.
- Enable DoS protection and SYN flood protection.
- Drop malformed packets and IP fragments.
- Disable response to ICMP redirects, source routing, directed broadcasts.

- **Data Plane (Traffic) Hardening**

- Implement “deny-by-default” rule strategy.
- Explicitly allow only required traffic.
- Review, reorder, and optimize rules for performance.
- Enforce stateful inspection and deep packet inspection where applicable.
- Apply TLS inspection (if governance allows).



Firewall Hardening – Policy Hardening

- **Rule Base Hardening**

- Remove unused rules.
- Remove shadowed or duplicate rules.
- Enforce rule naming standards for traceability.
- Group rules by service, zone, or role.
- Apply rule expiration dates for temporary access.

- **Object Hardening**

- Remove unused IP/service objects.
- Use standardized naming conventions.
- Avoid “Any-Any-Allow” rules.
- Avoid broad netmasks such as /0 or /8 unless absolutely required.

Firewall Hardening – Logging, Monitoring, and Auditing

▪ **Logging**

- Enable full logging for allow/deny actions.
- Log configuration changes with timestamps and admin identity.

▪ **Monitoring**

- Enable health and performance monitoring.
- Enable alerting for critical events (failover, link down, CPU spikes).
- Integrate with NMS tools (e.g., Nagios, Zabbix, SolarWinds).

▪ **Auditing**

- Implement periodic rule base reviews.
- Use automated compliance tools (CIS Benchmark Scanner, Nipper, Tufin, AlgoSec).
- Retain logs as per compliance requirements (PCI-DSS, HIPAA, ISO 27001).



Firewall Hardening – Network Architecture Hardening

- **Network Segmentation**

- Use VLANs, Keep DMZ, Internal, and External networks strictly separated.
- Enforce granular East-West rules.

- **High Availability (HA)**

- Deploy firewall clusters in Active/Passive or Active/Active mode.
- Synchronize configurations across clusters.
- Periodically test failover readiness.

- **Redundancy**

- Use redundant links and routing paths.
- Keep backup of configuration files in a secure vault.



Firewall Hardening – Advanced Security Hardening

- **IPS/IDS Integration**

- Enable IPS signatures for exploit detection, Tune signatures to reduce false positives.

- **Web Application Firewall (WAF)**

- Protect web applications in DMZ.

- **Threat Intelligence**

- Enable dynamic threat feeds.
- Block known malicious IPs, domains, URLs.

- **Zero Trust Alignment**

- Verify identity before granting access, Enforce continuous authentication.
- Use micro-segmentation inside networks.



Firewall Policies

- A firewall policy is a structured and predefined set of rules that determine how a firewall *handles incoming, outgoing, or transiting network* traffic.
- These rules enforce the organization's security posture by allowing or denying specific types of traffic based on multiple criteria such as *source/destination IP, ports, protocols, users, applications, and content*.
- Firewall policies ensure that only *authorized, legitimate, and necessary communication is permitted*, while all other traffic is blocked or inspected.



Purpose of Firewall Policies

Firewall policies are created to:

- Enforce least privilege access to networks.
- Protect internal resources from external threats.
- Control user and system communication.
- Segment networks (LAN, DMZ, WAN, Data Centre).
- Meet compliance requirements (PCI-DSS, HIPAA, ISO 27001).
- Provide visibility and logging of traffic events.
- Prevent lateral movement in Zero Trust environments.



Components of a Firewall Policy

- **Source** (IP, Subnet, Zone, or User)
- **Destination** (IP, Subnet, Zone, URL, Application)
- **Service** / Port / Protocol
- **Action** (Allow / Deny / Drop / Reject)
- **Schedule** (Optional)
- **Logging**
- **Security Profiles** (for NGFW)
- **NAT Policies** (If Enabled)



Types of Firewall Policies

- **Inbound Policies**

- Control traffic entering the organization's network from external networks.

- **Outbound Policies**

- Control traffic leaving internal networks for the Internet.

- **Inter-Zone Policies**

- Control internal traffic between network segments.

- **VPN Policies**

- Control remote-user or site-to-site VPN traffic.

Types of Firewall Policies

- **NAT Policies**

- Define how IP translation occurs.

- **Application-Based Policies (NGFW)**

- Control traffic based on the application, not just ports.

- **User-Based Policies**

- Based on identity from AD/LDAP.

- **URL Filtering Policies**

- Control access to categories of websites.

Firewall Policy Lifecycle

- **Requirement Gathering**

- Identify purpose, application owner, security risks.

- **Risk Assessment**

- Validate if the requested connection is legitimate.

- **Design**

- Define zones, ports, protocols, security profiles.

- **Implementation**

- Create rules in the firewall.

- **Testing & Validation**

- Ensure traffic flows as expected.

- **Documentation**

- Record rule purpose, owner, expiration.

- **Review & Optimization**

- Check for redundancy, shadowing, misuse.

Example Firewall Policies

Database Access

- Source: Web Application Server
- Destination: Database Server
- Service: TCP 1433
- Action: Allow
- Logging: Enabled

Block Social Media

- Source: Employees
- Destination: Internet
- Application: Facebook
- Action: Block
- Logging: Enabled

Types of Firewalls

1. Packet-Filtering Firewall (Stateless Firewall)
2. Stateful Inspection Firewall (Dynamic Packet Filtering)
3. Circuit-Level Gateway Firewall
4. Application-Level Gateway Firewall (Proxy Firewall)
5. Next-Generation Firewall (NGFW)
6. Web Application Firewall (WAF)
7. Cloud Firewall (Firewall-as-a-Service, FWaaS)
8. Host-Based Firewall
9. Virtual Firewall (vFirewall)
10. Distributed Firewall
11. UTM Firewall (Unified Threat Management)



Top Firewalls Required in Any Enterprise

- **Next-Generation Firewall (NGFW)**
 - Mandatory at the Perimeter
- **Web Application Firewall (WAF)**
 - Mandatory for Web, API, and Cloud Applications
- **Host-Based Firewalls**
 - Mandatory for Endpoint and Server Protection



Next-Generation Firewall (NGFW)

- A Next-Generation Firewall is the primary security gateway between the enterprise and the outside world (Internet, partners, WAN).
- It replaces legacy packet-filtering and stateful devices by providing deep inspection and integrated threat prevention.
- **Key Enterprise Capabilities**
 - Application-level awareness (Layer 7)
 - Intrusion Prevention System (IPS)
 - Threat intelligence feeds
 - Anti-malware scanning
 - User identity integration (AD/LDAP)
 - SSL/TLS decryption and inspection
 - URL filtering
 - Site-to-site & remote-access VPN



Next-Generation Firewall (NGFW)

Why enterprises cannot operate without NGFW:

- Protects the network perimeter
- Stops modern attacks (malware, exploits, command-and-control, ransomware)
- Ensures regulatory compliance (PCI, HIPAA, ISO27001)
- Provides full visibility and strong policy enforcement
- Examples:
 - Palo Alto,
 - FortiGate,
 - Check Point,
 - Cisco Firepower



Web Application Firewall (WAF)

Almost every enterprise hosts:

- Customer, Employee portals
- APIs, Mobile app backends
- Cloud workloads
- All of them are exposed to the Internet and are the top attack targets.

Key Enterprise Capabilities

- Protects web applications and APIs
- Stops OWASP Top 10
- (SQL Injection, XSS, CSRF, RCE, Path Traversal, etc.)
- API schema enforcement
- Bot mitigation
- TLS termination and inspection



Web Application Firewall (WAF)

Why enterprises cannot operate without WAF:

- Public-facing apps are primary breach vectors
- Firewalls and NGFWs cannot detect or block Layer-7 application attacks
- Compliance: PCI-DSS mandates WAF for applications handling cardholder data
- Examples:
 - F5,
 - Cloudflare WAF,
 - Akamai WAF,
 - FortiWeb,
 - AWS WAF



Host-Based Firewalls

- A host firewall enforces local security controls and reduces the attack surface per device.
- Key Enterprise Capabilities
 - Blocks lateral movement inside corporate LAN
 - Controls inbound/outbound traffic per machine
 - Enforces Zero Trust segmentation
 - Required for regulatory compliance (ISO, CIS, NIST)
 - Protects assets even when the device is offsite (WFH users)



Host-Based Firewalls

Why enterprises cannot operate without Host Firewalls:

- Modern ransomware spreads laterally across internal networks
- Zero Trust mandates micro-segmentation, enforced at the endpoint
- Servers require host-level protection regardless of network-layer segmentation
- Cloud VMs, laptops, and mobile devices require local access control
- Examples:
 - Windows Defender Firewall,
 - Linux IPTables/NFT,
 - macOS PF



Why Not Other Firewalls?

- **Packet-filtering and Stateful firewalls** → Outdated; replaced by NGFW.
- **Circuit-level and Proxy firewalls** → Use-case specific; not universal.
- **Virtual/Distributed firewalls** → Needed in cloud/SDN environments, not every enterprise.
- **Cloud firewalls (FWaaS)** → Critical for cloud-first companies, but not universal.
- **UTM Firewalls** → Good for SMBs; not suitable for large enterprises.



Advantages of Firewalls

Advantages of Firewalls	Details / Explanation
Network Protection	Firewalls block unauthorized access and prevent external threats from entering the internal network.
Traffic Monitoring & Control	They inspect inbound/outbound traffic and enforce security policies to ensure only legitimate traffic flows.
Prevents Malware & Attacks	Advanced firewalls (NGFW, UTM) detect and block malware, ransomware, intrusion attempts, DoS/DDoS, etc.
Enforces Access Control	Firewalls allow administrators to define granular rules for applications, ports, IPs, and protocols.
Supports Logging & Auditing	Firewalls maintain logs for security analysis, compliance audits, SIEM integration, and incident investigation.
Protects Against Data Exfiltration	Can restrict outbound connections, preventing unauthorized data leaks.
Application-Level Security (Layer 7)	NGFW and WAF filter traffic based on applications, APIs, user identity, and behavioral patterns.
VPN Support	Many firewalls provide secure remote access through IPSec/SSL VPN tunnels.
Segmentation & Micro-Segmentation	Firewalls help isolate network zones (LAN, DMZ, servers, cloud workloads).

Disadvantages of Firewalls

Disadvantages of Firewalls	Details / Explanation
Cannot Protect Against Insider Threats Alone	Firewalls focus on perimeter security and cannot stop malicious activities performed by internal users without additional tools.
Cannot Protect Against Malware Already Inside	If a system is infected internally, the firewall may not detect it unless it has advanced threat detection.
Performance Overhead	Deep inspection (Layer 7 filtering, SSL decryption, IDS/IPS) may slow network throughput and require high-performance hardware.
Requires Continuous Management	Rule updates, logs, firmware upgrades, policy tuning, and monitoring demand skilled administrators.
False Positives / False Negatives	Incorrect rules may block legitimate traffic or fail to stop harmful traffic.
Not a Complete Security Solution	Firewalls must be complemented with endpoint security, identity security, SIEM, EDR/XDR, patching, etc.
Cost	Enterprise-grade NGFW/UTM solutions and high-availability clusters can be expensive.
Cannot Protect Against Encrypted Attacks Without SSL Inspection	Attackers may hide malicious payloads inside encrypted HTTPS traffic unless SSL decryption is enabled.
Limited in Protecting Against Social Engineering	Firewalls cannot prevent phishing, vishing, or credential theft by tricking users.



Firewall Throughput

- Firewall Throughput refers to the maximum volume of network traffic a firewall can process and forward per second (Mbps/Gbps) while applying all configured security policies.
- It is one of the most critical performance metrics used to evaluate a firewall's capacity and suitability for enterprise environments.
- It represents the firewall's capability to handle network load while performing functions such as:
 - Packet inspection
 - Application-layer inspection
 - SSL/TLS decryption
 - Stateful analysis
 - IPS/IDS scanning
 - NAT, VPN encryption, routing



Types of Throughput Metrics

Firewalls usually publish multiple throughput values because performance varies based on enabled features.

- **SSL Inspection Throughput**

- Measures performance when HTTPS traffic is decrypted and inspected.
- Consumes high CPU; throughput often drops to 30–50% of raw throughput.

- **VPN Throughput**

- Measures encrypted site-to-site or client VPN traffic throughput.
- Dependent on encryption algorithms (AES-256 higher load vs AES-128).

- **Raw Firewall Throughput (Layer 3 Throughput)**

- Basic packet forwarding and filtering (stateless/stateful).
- Measured with minimal security features enabled.
- Highest throughput number (marketing value).

- **Threat Prevention Throughput**

- Includes IPS, Anti-Malware, URL filtering, etc.
- More realistic for enterprise use.
- Significantly lower than raw throughput.

Why Throughput Matters?

Throughput determines whether the firewall can handle:

- Peak network traffic loads
- Large numbers of concurrent users
- High-volume VPN connections
- High-speed uplinks (1G, 10G, 40G, 100G)
- Cloud-scale traffic

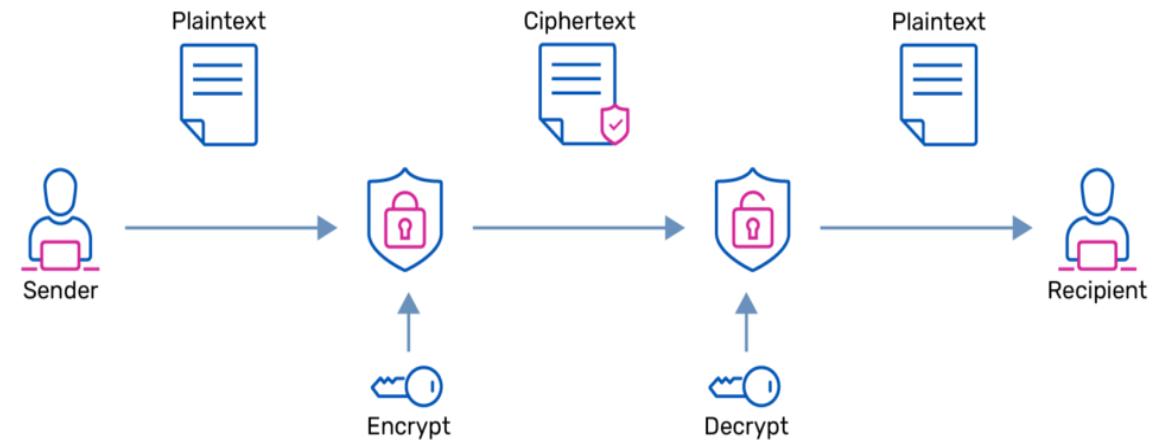


Factors Affecting Firewall Throughput

Factor	Impact
Security features enabled	IPS, WAF, anti-malware reduce throughput significantly.
Encryption load	SSL/TLS and VPN encryption consumes CPU resources.
Packet size	Smaller packets reduce throughput due to processing overhead.
Hardware capabilities	CPU cores, RAM, ASIC/FPGA acceleration improve throughput.
Rule complexity	More rules = more processing = less throughput.
Application type	Apps like streaming or file transfers generate large volumes.
Traffic mix	Real-world traffic reduces throughput vs lab test results.

SSL Decryption

- SSL Decryption (also known as **SSL/TLS Inspection**) is the process of decrypting encrypted internet traffic to inspect its contents for security threats or policy violations.
- It is a critical cybersecurity capability, as most web traffic is encrypted, and without decryption, threats can hide inside these secure channels.
- By using this, **Next-Generation Firewall (NGFW)**, **Web Application Firewall (WAF)**, or **proxy** decrypts encrypted traffic, inspects it for threats, and then re-encrypts it before sending it to the destination.



Why SSL Decryption is Needed ?

- Modern attackers use encryption as a **shield**, hiding malicious payloads inside HTTPS.
- Without SSL inspection, the firewall sees only:
 - Source IP
 - Destination IP
 - Port number (usually 443)
 - Packet sizes

...NOT the actual content.

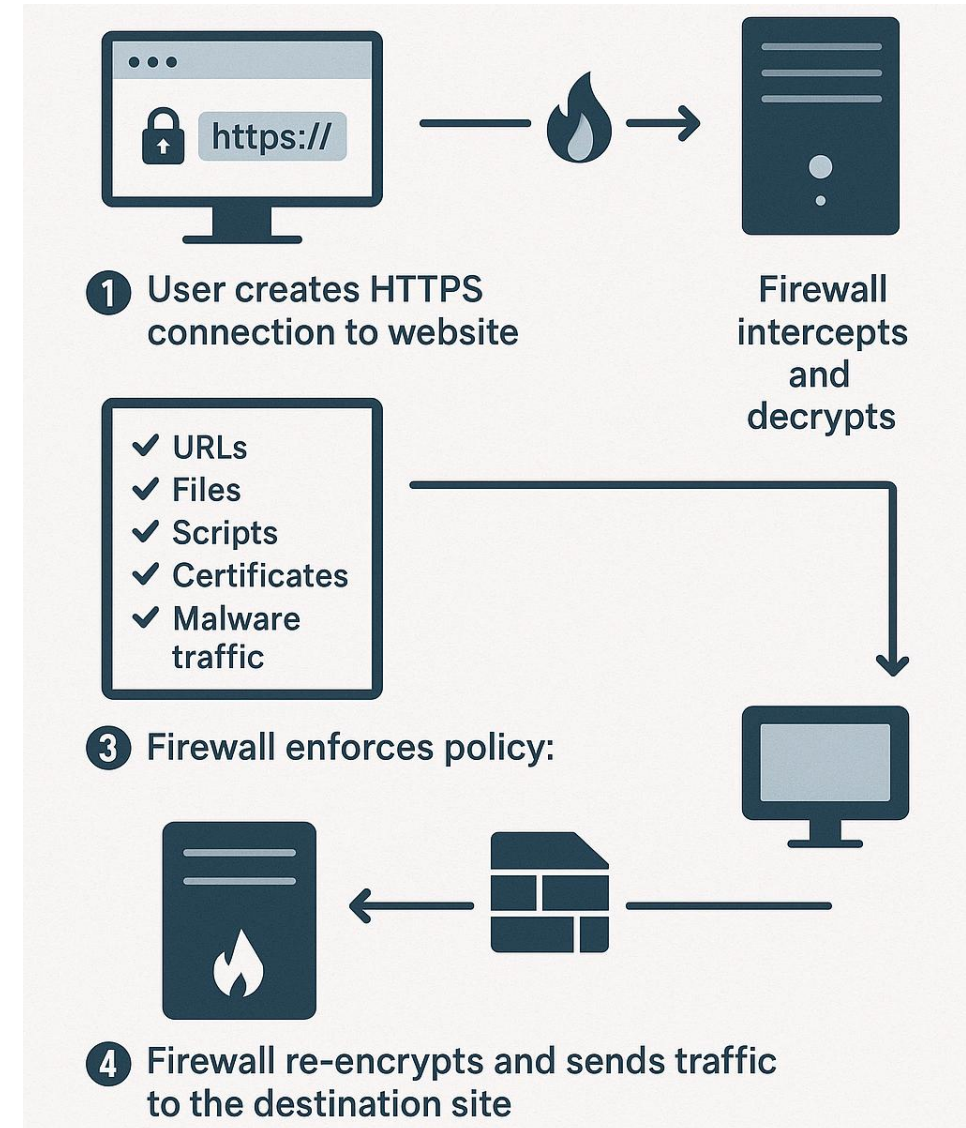
Threats hidden in encrypted traffic

- Malware downloads
- Ransomware communication
- Remote access trojans
- Encrypted phishing sites
- Credential theft
- SSL-based VPN tunnels used as backdoors
- Insider data exfiltration (HTTPS uploads)

Modern enterprises MUST decrypt and inspect SSL traffic to ensure full security.

How SSL Decryption Works? (User → Internet)

1. User creates HTTPS connection to website.
2. Firewall intercepts and decrypts the connection.
3. Firewall inspects:
 - URLs
 - Files
 - Scripts
 - Certificates
 - Malware traffic
4. Firewall enforces policy:
 - Allow
 - Block
 - Quarantine
5. Firewall re-encrypts and sends traffic to the destination site.



How SSL Decryption Works? (Internet → Enterprise Server)

Used for inspection of traffic coming to internal hosted applications.

1. Public server certificate installed on firewall.
2. Firewall decrypts incoming HTTPS traffic.
3. Inspects for attacks (SQLi, XSS, exploits, bots).
4. Cleans and forwards to internal server.
5. Re-encrypts on return path.



Types of SSL Decryption

▪ Inbound SSL/TLS Decryption

- Used when you host public-facing services such as:
 - ✓ Web applications
 - ✓ Customer portals
 - ✓ APIs
 - ✓ Email servers (OWA)

The firewall uses the public certificate to decrypt inbound traffic.

▪ Outbound SSL/TLS Decryption

- Used for corporate users accessing external websites.
 - ✓ Most common
 - ✓ Requires internal root certificate installation in user endpoints
 - ✓ Allows detection of C2 and phishing

Where SSL Decryption Is Applied in an Enterprise

- Perimeter firewalls
- WAFs protecting web applications
- Proxy servers
- Secure Web Gateways
- CASB/SASE platforms
- Cloud firewalls (FWaaS)

Vendors That Support SSL Decryption

- Palo Alto Networks
- Fortinet FortiGate
- Cisco Firepower
- Check Point
- Sophos
- SonicWall
- Zscaler (cloud HTTPS inspection)
- Cloudflare Zero Trust
- AWS Firewall Manager
- Azure Firewall Premium



That's all Folks!